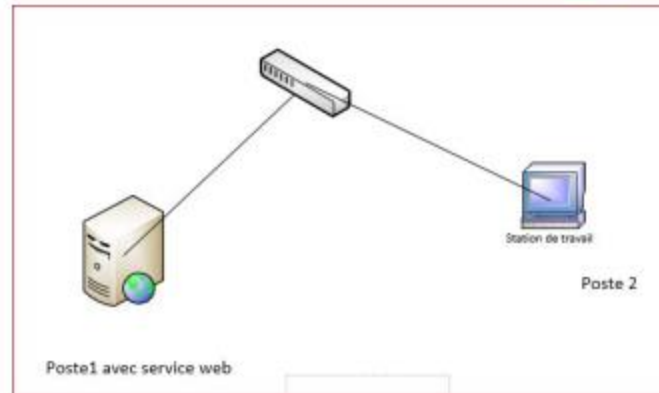


TP- Découverte IPTABLES

Voici le réseau à mettre en place avant de pouvoir débiter le TP. Il vous faudra un poste avec un serveur web (type apache) et ssh ainsi qu'un poste client.



Sommaire



Belerge Jérémie

BTS SIO 2

TP1: page 1

[-Schéma réseau ...p.3](#)

[-IPTABLES, c'est quoi ? ... p.4](#)

[-Installation d'iptables ... p.4](#)

[-Utilisation d'iptables ... p.5 à p.9](#)

[5.1. Comment bloquer le ping d'une machine cliente vers le serveur ...p.5](#)

[5.2. Permettre d'accéder au serveur uniquement en HTTP ... p.6](#)

[5.3. Bloquer l'accès d'une IP au serveur web ...p.7](#)

[5.4. Bloquer l'accès Telnet ou SSH au serveur ...p.8](#)

[5.5. \(Bonus\) Rétablir l'accès Telnet ou SSH au serveur ... p.9](#)

[-Règles correspondant aux demandes ... p.10 à p 14](#)

[6.1. Le client n'accède qu'au service web ...p.10](#)

[6.2. Le client ne peut pas ping le serveur ...11](#)

[6.3. Le client ne peut pas être ping ...p.12](#)

[6.4. Le serveur est uniquement un serveur web ...p13](#)

[6.5. Autoriser uniquement les connexions établies ... p.14](#)

TP2: page 15

[-Schéma réseau ...p.15](#)

[-Gestion de la DMZ ... p.16 à p.18](#)

[-Notre DMZ est accessible de partout donc d'internet et de notre réseau local...p17](#)

[-Pour éviter que nos serveurs soient victimes d'une attaque de - DDOS le ping n'est pas autorisé depuis l'extérieur...p17](#)

[-Par contre pour vérifier la connectivité le ping depuis le LAN reste possible...p17](#)

[-Le serveur SSH peut se connecter aux postes de la DMZ...p18](#)

[-Gestion de la LAN ... p.18 à p 20](#)

[Autorisez le ping de tous les postes du réseau privé sur l'interface LAN du routeur...p18](#)

[Autorisez le routage des paquets provenant du réseau privé vers la DMZ...p18](#)

[Camoufler les adresses Ip des postes du réseau privé qui vont sur internet...p19](#)

[_le poste du comptable ne peut pas aller sur internet : on travaillera avec l'@ MAC...p19](#)

[on n'acceptera que les connexions établies...p20](#)

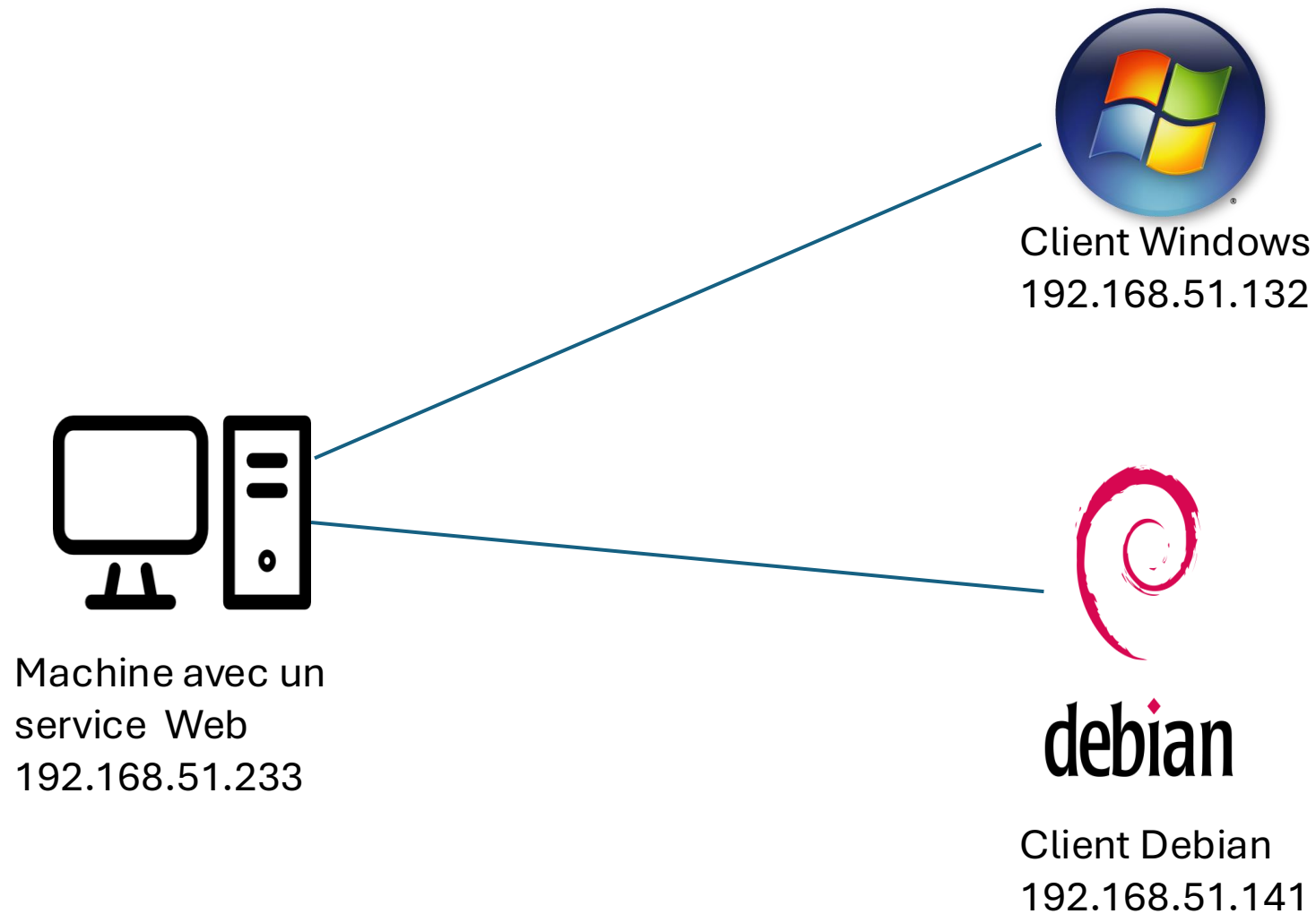
[on n'acceptera que les connexions établies...p20](#)

Schéma réseau



Belerge Jérémie

BTS SIO 2





Consignes:

-IPTABLES c'est quoi ?

IPTABLES c'est quoi ?

iptables est l'outil standard de pare-feu sous Linux pour gérer le trafic réseau au niveau du noyau.

Il utilise des **tables** (filter, nat, mangle) contenant des **chaînes** (INPUT, OUTPUT, FORWARD) où tu ajoutes des règles pour inspecter les paquets IP.

Règles basiques

- **ACCEPT** : autorise le paquet.
- **DROP** : ignore silencieusement.
- **REJECT** : refuse avec un message ICMP.

Source : [Wikipedia](#)

Pour faire simple , IPTABLE agit comme un pare-feu en filtrant les ports et IP.



Consignes:

-Installation & utilisation de IPTABLES

Comment installer IPTABLES :

Apt install iptables

```
root@debian-template:~# apt install iptables
```

Utilisation de IPTABLES :

Comment bloquer le ping d'une machine cliente vers le serveur ? :

```
root@debian-template:/home/jrm# iptables -A OUTPUT -p icmp -d 192.168.51.232 -j DROP
```

Iptables -A OUTPUT -p icmp -d 192.168.51.232 -j DROP

- -A OUTPUT : on ajoute une règle à la chaîne **OUTPUT** (paquets qui **sortent** du serveur).
- -p icmp : on cible le protocole **ICMP** (ping).
- -d 192.168.51.232 : destination (IP de la machine cliente)
- -j DROP : on **jette** silencieusement les paquets

Avant la commande depuis le client :

```
C:\Users\client1>ping 192.168.51.233

Envoi d'une requête 'Ping' 192.168.51.233 avec 32 octets de données :
Réponse de 192.168.51.233 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.51.233 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.51.233 : octets=32 temps=1 ms TTL=64
Réponse de 192.168.51.233 : octets=32 temps=1 ms TTL=64

Statistiques Ping pour 192.168.51.233:
    Paquets : envoyés = 4, reçus = 4, perdus = 0 (perte 0%),
    Durée approximative des boucles en millisecondes :
        Minimum = 1ms, Maximum = 1ms, Moyenne = 1ms
```

Après la commande depuis le client :

```
C:\Users\client1>ping 192.168.51.233

Envoi d'une requête 'Ping' 192.168.51.233 avec 32 octets de données
Délai d'attente de la demande dépassé.
Délai d'attente de la demande dépassé.

Statistiques Ping pour 192.168.51.233:
    Paquets : envoyés = 2, reçus = 0, perdus = 2 (perte 100%),
```



Consignes:

-Utilisation de IPTABLES

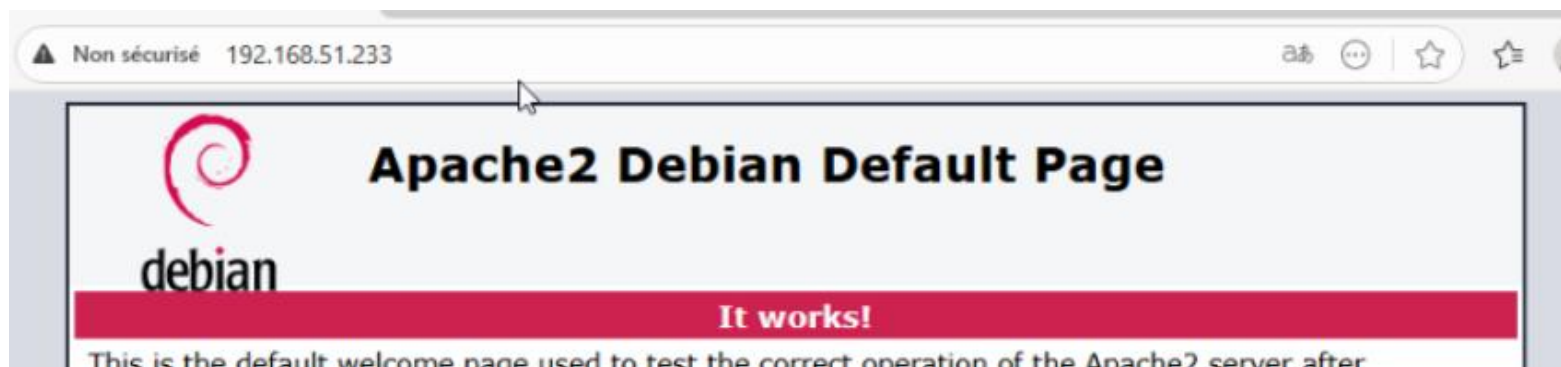
Permettre l'accès en HTTP (port 80) uniquement au serveur ?

```
root@debian-template:/home/jrm# iptables -A INPUT -p tcp --dport 80 -j ACCEPT
```

`Iptables -A INPUT -p tcp --dport 80 -j ACCEPT`

- **-A INPUT** : on ajoute une règle à la chaîne INPUT (paquets qui rentrent dans le serveur).
- **-p tcp** : on cible le protocole tcp.
- **--dport** : le port de destination , ici 80.
- **-j ACCEPT** : on **autorise les paquets**

Résultat depuis le client :





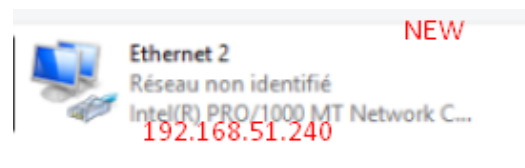
Interdire l'accès au serveur web à une IP :

```
root@debian-template:/home/jrm# iptables -A INPUT -s 192.168.51.240 -p tcp --dport 80 -j DROP
```

Iptables -A INPUT -s 192.168.51.240 -p tcp -dport 80 -j DROP

- -A INPUT : on ajoute une règle à la chaîne INPUT (paquets qui rentrent dans le serveur).
- -s 192.168.51.240 : la source , celui qui fait la demande (l'IP cible)
- -p tcp : on cible le protocole tcp.
- --dport : le port de destination , ici 80.
- -j ACCEPT : on autorise les paquets

Exemple si on change de carte réseaux avec une IP différente :



Désolé, impossible d'accéder à cette page.

http://192.168.51.233/ est inaccessible.

Exemple si on prend notre ancienne carte réseaux :





Consignes:

-Utilisation de IPTABLES

Refuser une connection Telnet Ou SSH :

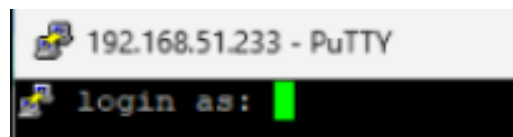
```
root@debian-template:/home/jrm# iptables -A INPUT -p tcp --dport 22 -j DROP
```

Iptables -A INPUT -p tcp -dport 22 -j DROP (Pour le SSH)

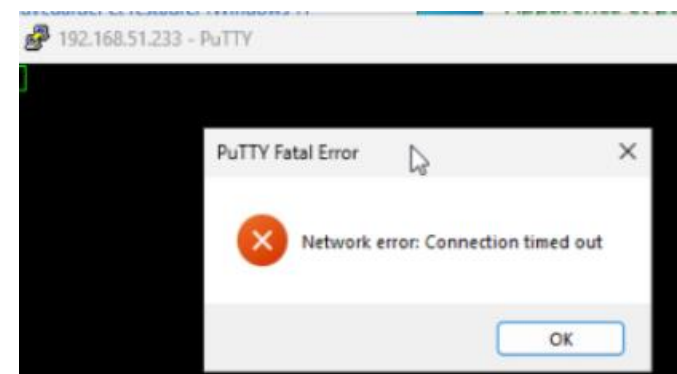
Iptables -A INPUT -p tcp -dport 23 -j DROP (Pour le telnet)

- **-A INPUT** : on ajoute une règle à la chaîne INPUT (paquets qui rentrent dans le serveur).
- **-p tcp** : on cible le protocole tcp.
- **--dport** : le port de destination , ici 22 OU 23.
- **-j DROP** : on **refuse silencieusement les paquets**

Exemple avec le port 22 avant la
commande :



Exemple avec le port 22 après la
commande :





Consignes:

-Utilisation de IPTABLES

Réactiver une connexion Telnet ou SSH :

```
root@debian-template:/# iptables -I INPUT -p tcp --dport 22 -j ACCEPT
```

Iptables -I INPUT -p tcp -dport 22 -j ACCEPT (Pour le SSH)

Iptables -I INPUT -p tcp -dport 23 -j ACCEPT (Pour le telnet)

- **-I INPUT** : on insere la règle en premier dans INPUT (paquets qui rentrent dans le serveur).
- **-p tcp** : on cible le protocole tcp.
- **--dport** : le port de destination , ici 22 OU 23.
- **-j ACCEPT**: on **autorise les paquets**.

Résultat de la commande :

```
jrm@debian-template: ~  
login as: jrm  
jrm@192.168.20.48's password:  
Linux debian-template 6.1.0-41-amd64  
25-11-09) x86_64
```



Le client ne peut accéder qu'au service web :

```
root@debian-template:/home/jrm# iptables -A OUTPUT -p tcp -d 192.168.51.233 --dport 80 -j ACCEPT
root@debian-template:/home/jrm# iptables -A OUTPUT -j DROP
```

(Depuis la machine client ubuntu)

```
Iptables -A OUTPUT -p tcp -d 192.168.51.233 --dport 80 -j ACCEPT
```

- **-A OUTPUT** : on la règle a la chaine OUTPUT (paquets qui sortent de la machine).
- **-p tcp** : on cible le protocole tcp.
- **-d 192.168.51.233** : on cible l'ip du serveur web.
- **--dport** : le port de destination , ici 80.
- **-j ACCEPT**: on **autorise les paquets**.

```
Iptables -A OUTPUT -j DROP
```

- **-A OUTPUT** : on la règle a la chaine OUTPUT (paquets qui sortent de la machine).
- **-j DROP** : ici on "jete" tout ce **qui n'est pas autorisé par le iptables**

Résultat de la commande :

La machine n'aura accès uniquement à la page web du serveur web avec l'IP : 192.168.51.133

Consignes:

-Les règles correspondant aux demandes



Consignes:

-Les règles
correspondant aux
demandes

Le client ne peut pas pinguer le serveur :

```
root@debian-template:/home/jrm# iptables -A INPUT -p icmp -s 192.168.51.241 -j DROP
```

(Depuis le serveur)

```
Iptables -A INPUT -p icmp -s 192.168.51.241 -j DROP
```

- **-A INPUT** : on la règle a la chaine INPUT (paquets qui rentrent dans le serveur).
- **-p icmp** : on cible le protocole icmp (PING).
- **-s 192.168.51.233** : ayant pour source (qui fait la demande) notre machine client (192.168.51.241) .
- **-j DROP**: on **bloque les paquets qui proviennent de la machine client.**

Résultat de la commande :

La machine ne peut pas ping notre serveur.

```
root@debian-template:/etc/network# ping 192.168.51.133
PING 192.168.51.133 (192.168.51.133) 56(84) bytes of data.
^C
--- 192.168.51.133 ping statistics ---
172 packets transmitted, 0 received, 100% packet loss, time 175082ms
```



Consignes:

-Les règles
correspondant aux
demandes

Le client ne peut pas être ping:

(Depuis le client)

```
iptables -A INPUT -p icmp -j DROP
```

- **-A INPUT** : on la règle a la chaine INPUT (paquets qui rentrent dans le serveur).
- **-p icmp** : on cible le protocole icmp (PING).
- **-j DROP**: on **bloque tout les paquets , provenant de n'importe quelle machine** .

Résultat de la commande :

La machine ne peut pas être ping .

Avant la commande:

```
root@debian-template:/# ping 192.168.51.241
PING 192.168.51.241 (192.168.51.241) 56(84) bytes of data.
64 bytes from 192.168.51.241: icmp_seq=1 ttl=64 time=0.600 ms
64 bytes from 192.168.51.241: icmp_seq=2 ttl=64 time=0.761 ms
64 bytes from 192.168.51.241: icmp_seq=3 ttl=64 time=0.577 ms
```

Après la commande:

```
root@debian-template:/# ping 192.168.51.241
PING 192.168.51.241 (192.168.51.241) 56(84) bytes of data.
^C
--- 192.168.51.241 ping statistics ---
35 packets transmitted, 0 received, 100% packet loss, time 34823ms
```



Consignes:

-Les règles
correspondant aux
demandes

Le serveur est uniquement un serveur web:

(Depuis le serveur)

```
iptables -A INPUT -p tcp --dport 80 -j ACCEPT
```

- **-A INPUT** : on la règle a la chaine INPUT (paquets qui rentrent dans le serveur).
- **-p icmp** : on cible le protocole tcp.
- **-dport 80** : On cible le port HTTP (80)
- **-j ACCEPT**: on **autorise a accéder au service web** .

```
sudo iptables -A INPUT -j DROP
```

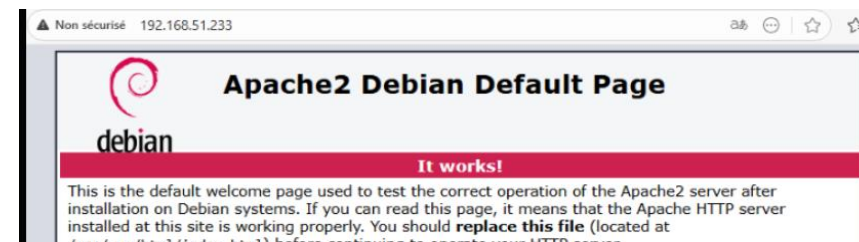
- **-A INPUT** : on la règle a la chaine INPUT (paquets qui rentrent dans le serveur).
- **-j DROP** : on **bloque tout les services qui ne sont pas dans la iptables**.

Résultat , on peut uniquement accéder à la page web du serveur :

```
root@debian-template:/etc/network# ping 192.168.51.233
PING 192.168.51.233 (192.168.51.233) 56(84) bytes of data.
^C
--- 192.168.51.233 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3000ms
```

```
C:\Users\client1>ping 192.168.51.233

Envoi d'une requête 'Ping' 192.168.51.233 avec 32 octets de données :
Délai d'attente de la demande dépassé.
Délai d'attente de la demande dépassé.
```





Consignes:

-Les règles correspondant aux demandes

Autoriser uniquement les connexions établies :

(Depuis le serveur)

```
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
```

- **-A INPUT** : on la règle à la chaîne INPUT (paquets qui rentrent dans le serveur).
- **-m state** : vérifie l'état de la connexion
- **-dport 80** : On cible le port HTTP (80)
- **--state ESTABLISHED,RELATED** :
 - ESTABLISHED** : Connexions déjà actives (réponses aux requêtes)
 - RELATED** : Connexions liées (exemple : FTP)
- **-j ACCEPT** : Laisse passer ces paquets

Résultat :

Le serveur n'autorisera que les paquets correspondant aux règles iptables. Tout protocole/port qui n'est pas renseigné est automatiquement bloqué."

Ou plus simple :

"Seul ce qui est dans les règles iptables passe. Le reste est rejeté par défaut.

|B3| TP N° 6: IPTABLES TP2



Belerge Jérémy

BTS SIO 2

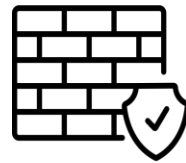
192.168.20.137

WAN



alamy

192.168.20.83
192.168.137.201
192.168.51.2



192.168.51.3

192.168.51.4

LAN



alamy

192.168.137.202

DMZ





Consignes:

-Gestion de la DMZ

On active le mode router sur notre machine qui gère les iptables:

```
root@debian-template:/home/jrm# nano /etc/sysctl.conf
```

On décommente cette ligne :

```
# Note: This may impact IPv6 TCP sessions too
net.ipv4.tcp_syncookies=1
```

Puis on redemarre notre sysctl.conf

```
sysctl -p /etc/sysctl.conf
```

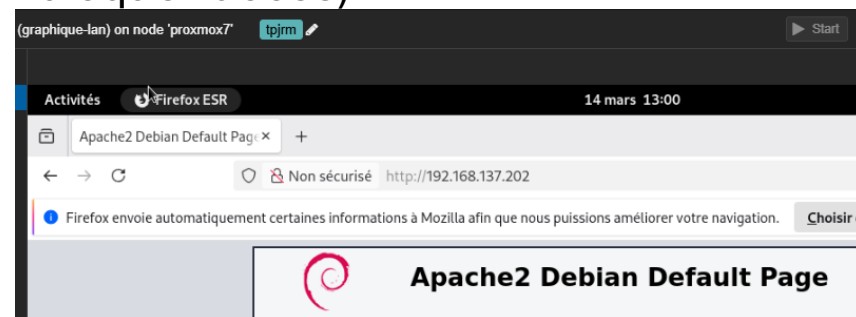
Attention pour la suite du tp il nous faut vérifier sur nos machines clientes qu'elles ont bien l'adresse IP de notre pare-feu en tant que passerelle, de plus il nous faut vérifier son "ip route", si il n'affiche pas la bonne IP, il faut taper :

```
ip route add default via "IP"
```

Depuis la WAN (sans règle qui bloque l'accès) :



Depuis le LAN (sans règle qui bloque l'accès)





Notre DMZ est accessible de partout donc d'internet et de notre réseau local :

```
root@debian-template:/home/jrm# iptables -A FORWARD -s 192.168.20.0/24 -d 192.168.137.0/24 -j ACCEPT
root@debian-template:/home/jrm# iptables -A FORWARD -s 192.168.51.0/24 -d 192.168.137.0/24 -j ACCEPT
```

Consignes:

-Gestion de la DMZ

Pour éviter que nos serveurs soient victimes d'une attaque de DDOS le ping n'est pas autorisé depuis l'extérieur:

```
iptables -A FORWARD -s 192.168.20.0/24 -d 192.168.137.0/24 -p icmp -j DROP
```

Avant la regle :

```
root@debian-graphique-template:/etc/network# ping 192.168.137.202
PING 192.168.137.202 (192.168.137.202) 56(84) bytes of data.
64 bytes from 192.168.137.202: icmp_seq=1 ttl=63 time=1.23 ms
64 bytes from 192.168.137.202: icmp_seq=2 ttl=63 time=1.30 ms
64 bytes from 192.168.137.202: icmp_seq=3 ttl=63 time=1.33 ms
64 bytes from 192.168.137.202: icmp_seq=4 ttl=63 time=1.06 ms
^C
```

Après la regle

```
PING 192.168.137.202 (192.168.137.202) 56(84) bytes of data.
^C
--- 192.168.137.202 ping statistics ---
3 packets transmitted, 0 received, 100% packet loss, time 2037ms
```

Par contre pour vérifier la connectivité le ping depuis le LAN reste possible:

```
iptables -A FORWARD -s 192.168.51.0/24 -d 192.168.137.0/24 -p icmp -j ACCEPT
```

```
root@debian-graphique-template:/etc/network# ping 192.168.137.202
PING 192.168.137.202 (192.168.137.202) 56(84) bytes of data.
64 bytes from 192.168.137.202: icmp_seq=1 ttl=63 time=1.43 ms
64 bytes from 192.168.137.202: icmp_seq=2 ttl=63 time=1.27 ms
64 bytes from 192.168.137.202: icmp_seq=3 ttl=63 time=1.32 ms
^C
```



Consignes:

-Gestion de la DMZ

-Gestion du LAN

Le serveur SSH peut se connecter aux postes de la DMZ:

```
iptables -A FORWARD -s 192.168.51.3 -d 192.168.137.0/24 -p tcp --dport 22 -j ACCEPT
```

Explication : Uniquement le serveur SSH peut se connecter au machine de la DMZ (via le port 22)

Gestion des postes du LAN

Autorisez le ping de tous les postes du réseau privé sur l'interface LAN du routeur :

```
iptables -A INPUT -i ens19 -p icmp -s 192.168.51.0/24 -j ACCEPT
```

```
root@debian-graphique-template:/etc/network# ping 192.168.51.2
PING 192.168.51.2 (192.168.51.2) 56(84) bytes of data.
64 bytes from 192.168.51.2: icmp_seq=1 ttl=64 time=1.32 ms
64 bytes from 192.168.51.2: icmp_seq=2 ttl=64 time=1.04 ms
64 bytes from 192.168.51.2: icmp_seq=3 ttl=64 time=0.711 ms
^C
```

Explication : Toute machine ayant une IP en 192.168.51.X pourra ping son interface LA (192.168.51.2)

Autorisez le routage des paquets provenant du réseau privé vers la DMZ :

```
iptables -A FORWARD -s 192.168.51.0/24 -d 192.168.137.0/24 -j ACCEPT
```

```
root@debian-graphique-template:/etc/network# ping 192.168.137.202
PING 192.168.137.202 (192.168.137.202) 56(84) bytes of data.
64 bytes from 192.168.137.202: icmp_seq=1 ttl=63 time=1.82 ms
```

Explication : Nos machines LAN peuvent ping des machines sur la DMZ



Consignes:

-Gestion du LAN

Camoufler les adresses Ip des postes du réseau privé qui vont sur internet:

```
iptables -t nat -A POSTROUTING -o ens18 -s 192.168.51.0/24 -j MASQUERADE
```

No.	Time	Source	Destination
51	19.049338625	192.168.20.172	192.168.20.83
52	19.999611029	Cisco_98:29:46	Spanning-tree-(for-
53	20.050972147	192.168.20.83	192.168.20.172

Explication : Maintenant lorsqu'une machine de notre LAN ping une machine sur la WAN au mieux de montrer "192.168.51.X" nous aurons l'IP attribué a notre routeur "192.168.20.83"

le poste du comptable ne peut pas aller sur internet : on travaillera avec l'@ MAC

```
iptables -A FORWARD -m mac --mac-source BC:24:11:9c:65:0A -j DROP
```

```
root@debian-graphique-template:/etc/network# ping 8.8.8.8
PING 8.8.8.8 (8.8.8.8) 56(84) bytes of data.
^C
--- 8.8.8.8 ping statistics ---
4 packets transmitted, 0 received, 100% packet loss, time 3076ms
```

Explication : Ce pc ne peut pas accéder a google , internet.



Consignes:

-Gestion du LAN

on n'acceptera que les connexions établies

```
iptables -A INPUT -m state --state ESTABLISHED,RELATED -j ACCEPT
```

Explication : On autorisera uniquement les connexions "connues" , renseigné dans notre iptable

Les paquets rejetés seront enregistrés dans le journal /var/log/syslog/

```
iptables -A INPUT -i ens18 -j LOG --log-prefix REFUS: --log-level 4
```

Explication : Tous les paquets qui sont rejetés depuis la WAN seront mis dans le dossier "/var/log/syslog".

Si on souhaite vérifier nos logs nous pouvons taper la commande :

```
tail -f /var/log/syslog
```